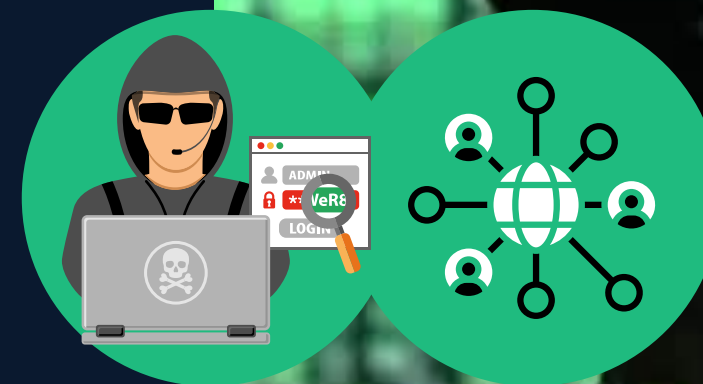


MULTIMEDIA UNIVERSITY, MALAYSIA

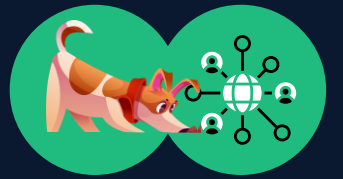
Network Sniffing

ETHICAL HACKING AND PENETRATION TESTING
CCS6324 - 2530

Dr. Hafiz Adnan Hussain

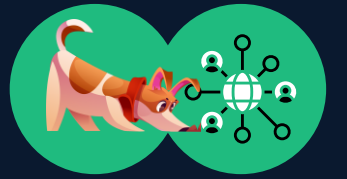


DISCLAIMER



- This course is designed to educate students on ethical hacking principles. The knowledge and techniques acquired must be used responsibly and not for any illegal or unauthorized activities.
- Each student is solely responsible for their actions.
- Do not investigate individuals, websites, servers or conduct any illegal activities on any system you do not have permission to analyze.
- The course content has been developed in good faith, drawing from the author's experience and reputable sources. While every effort has been made to ensure accuracy, the author does not guarantee absolute correctness. Students are encouraged to exercise discretion and actively engage in discussions by raising any questions or concerns during the course.

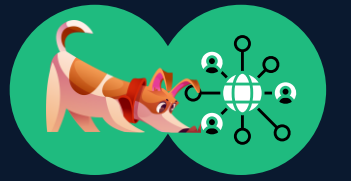
Learning Objectives



What You Will Learn?

- Understand network sniffing as an active reconnaissance and attack technique for intercepting network traffic.
- Distinguish between passive sniffing and active sniffing techniques, and identify appropriate network environments for each.
- Analyze the TCP/IP model layers to understand how data is encapsulated and transmitted across networks.
- Execute Man-in-the-Middle (MITM) attacks using ARP poisoning and DNS spoofing techniques in controlled lab environments.
- Identify network vulnerabilities, including unencrypted protocols, weak ARP authentication, and rogue DHCP servers.
- Apply defensive countermeasures such as encryption (HTTPS/TLS/VPN), network monitoring (IDS/IPS), and ARP inspection to prevent sniffing attacks.
- Evaluate real-world attack scenarios and recommend appropriate security controls based on network architecture and threat analysis

Introduction to Network Sniffing



Network sniffing is the process of capturing and analyzing network traffic in real-time. A network sniffer intercepts data packets as they travel across a network, allowing an analyst to examine their contents. This fundamental technique is used for both defensive security monitoring and malicious reconnaissance.

Definition:

Network sniffing involves placing a network interface in promiscuous mode, which allows the interface to capture all traffic on the network segment, not just traffic destined for the specific device. This captured data can reveal credentials, session information, and sensitive information being transmitted in unencrypted formats.

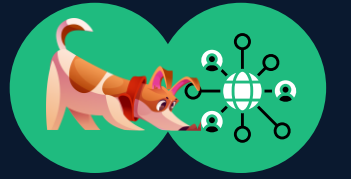
Legitimate Uses

- Network troubleshooting and performance monitoring
- Security auditing and penetration testing (with authorization)
- Network protocol analysis and debugging
- Intrusion detection and incident response
- Quality assurance testing

Malicious Uses

- Stealing login credentials and passwords
- Session hijacking and account takeover
- Capturing sensitive information (credit card numbers, SSN, etc.)
- Eavesdropping on private communications
- Corporate espionage and data theft

Types of Network Sniffing



Passive Sniffing

Definition: Silently capturing network traffic without altering or sending packets.

How It Works

- In hub-based networks, all traffic is broadcast to all connected devices. Passive sniffers simply listen to this broadcast traffic without generating any packets.
- In wireless networks, attackers can eavesdrop on radio waves transmitted by access points and devices.
- No special network manipulation is required, making it completely silent and undetectable.

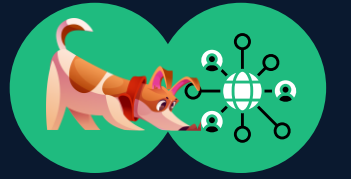
Examples

- Using **Wireshark** on a legacy hub-based network to capture HTTP traffic
- Capturing unencrypted credentials over **public Wi-Fi**
- Monitoring IoT device communications on a **shared network** segment

Advantages: Undetectable (generates no traffic), safe to perform, requires only standard network access.

Disadvantages: Limited to networks with broadcast or wireless traffic, cannot capture all traffic in modern switched networks.

Types of Network Sniffing (Cont'd)



Active Sniffing

Definition: Actively manipulating network traffic to force data through the attacker's system.

How It Works

- In switched networks, ports are isolated from each other. Active sniffing uses techniques like Address Resolution Protocol (ARP) spoofing or Media Access Control (MAC) flooding to bypass port isolation.
- The attacker generates crafted packets to redirect traffic destined for other hosts to the attacker's machine.
- Once traffic is redirected, the attacker can sniff, modify, or intercept the data before forwarding it to the legitimate destination.

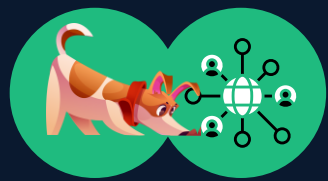
Examples

- ARP Poisoning: Sending forged ARP replies to associate the attacker's MAC address with a target's IP address
- MAC Flooding: Flooding the switch with forged MAC addresses to fill its MAC address table and cause it to broadcast traffic
- DHCP Spoofing: Running a rogue DHCP server to assign attacker-controlled DNS servers to victim machines

Advantages: Works on modern switched networks where passive sniffing is limited.

Disadvantages: Detectable by Intrusion Detection Systems (IDS), requires more technical knowledge, may disrupt network service.

Types of Network Sniffing (Cont'd)



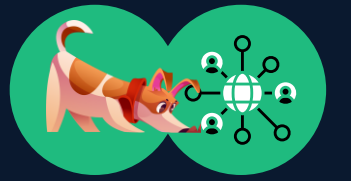
Comparison as per MIT vs. Stanford:

- **MIT** researchers have developed innovative approaches to more efficiently monitor network traffic in data centers, enabling the detection of activities such as sniffing and other cyber threats in Software-Defined Networking (SDN) environments. Their work focuses on enhancing security and privacy rather than simply sniffing.
- **Stanford University** offers resources and guidance on leveraging native cloud provider capabilities, such as AWS VPC Traffic Mirroring and Azure Virtual Network TAP, for network monitoring and security, as part of its general cloud services support and research into cloud security practices.

Comparison as per Passive vs Active Sniffing:

Aspect	Passive Sniffing	Active Sniffing
Traffic Generation	No packets sent	Attacker sends crafted packets
Network Type	Hubs, wireless	Switched networks
Stealth	Hard to detect	Risk of IDS/IPS alerts
Tools	Wireshark, tcpdump	Ettercap, BetterCAP

TCP/IP Network Model and Packet Structure



TCP/IP Model Overview

The TCP/IP model is the fundamental architecture for Internet communication. It consists of four layers, each with specific responsibilities. Understanding this model is essential for network sniffing because different attacks target different layers.

Layer 1: Physical Layer

Responsible for transmitting raw bits over physical media (copper cables, fiber optics, radio waves). Examples: Ethernet, Wi-Fi radio transmission.

Layer 2: Data Link Layer (Link Layer)

Responsible for moving data between two devices on the same network segment. Uses MAC (Media Access Control) addresses to identify devices. Examples: Ethernet frames, ARP (Address Resolution Protocol).

Layer 3: Network Layer (Internet Layer)

Responsible for routing packets across networks. Uses IP (Internet Protocol) addresses to identify devices across the internet. Examples: IPv4, IPv6, routing protocols.

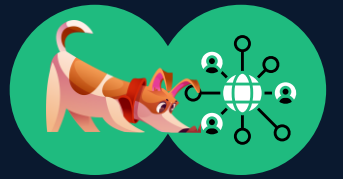
Layer 4: Transport Layer

Responsible for end-to-end communication between applications. Uses ports to identify specific services. Examples: TCP (connection-oriented), UDP (connectionless).

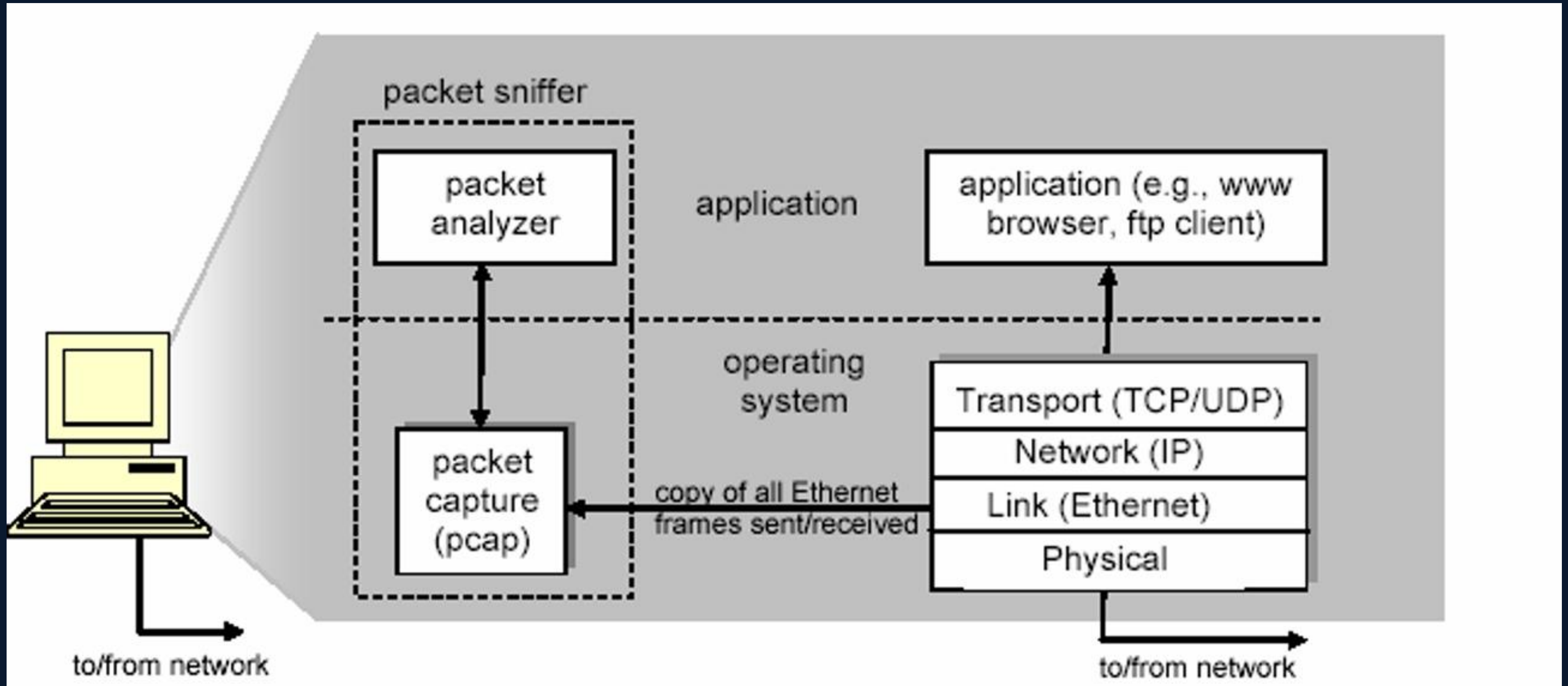
Layer 5-7: Application Layer

Contains protocols and services that end-users interact with. Examples: HTTP/HTTPS (web), SMTP (email), SSH (remote access), FTP (file transfer), DNS (domain resolution).

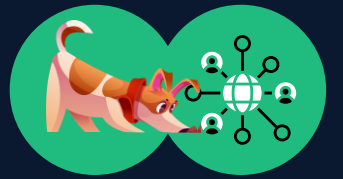
TCP/IP Network Model and Packet Structure



Packet Structure



TCP/IP Network Model and Packet Structure



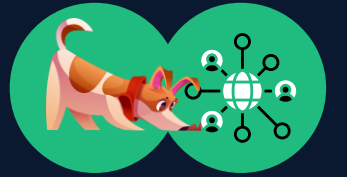
Packet Structure (Cont'd)

- Applications (Web browsers, FTP clients, email clients)
- Network protocols (Internet protocol)
- Packet capture
 - The packet capture library receives a copy of every link-layer frame that is sent from or received by your computer.
- Packet Analyzer
 - Displaying the contents of all fields within a protocol message
 - Understanding the structure of all messages exchanged by protocols
 - IP, TCP, HTTP headers
- Wireshark, TCPDump

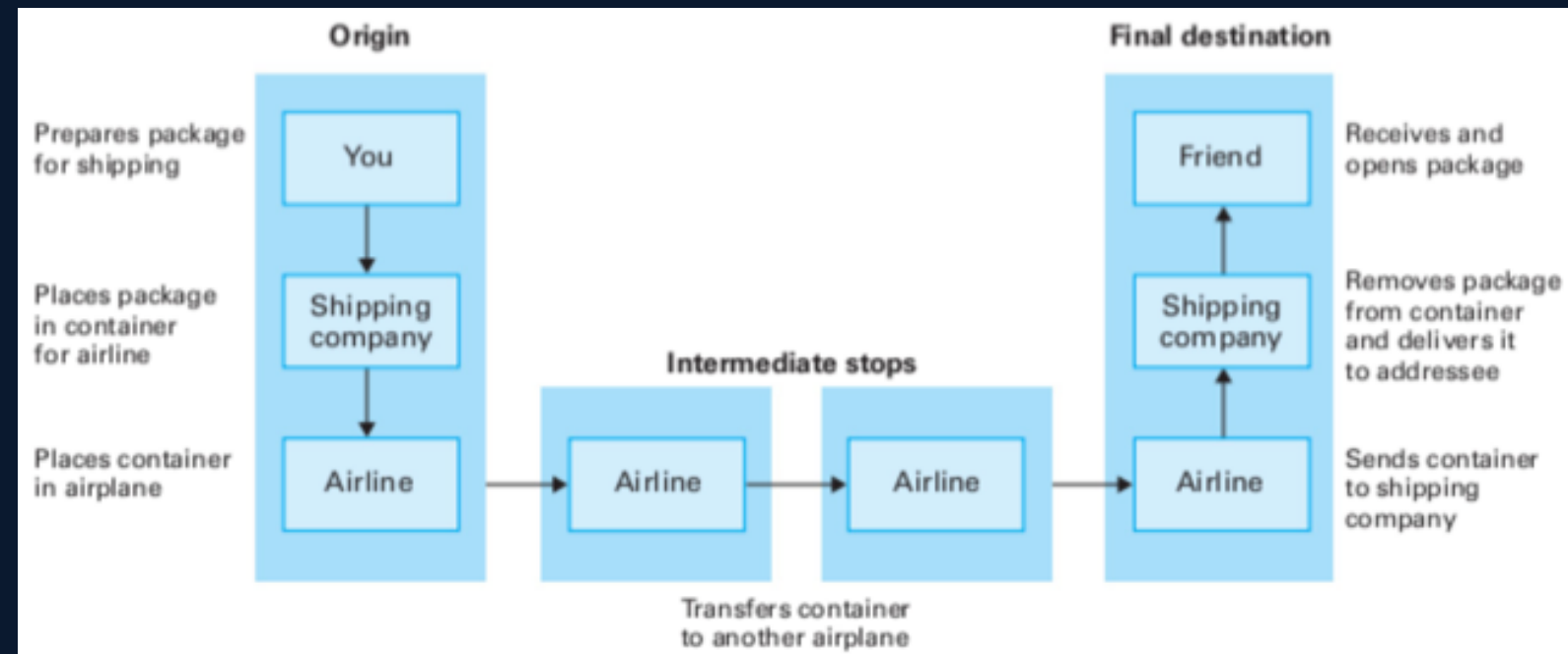
Widely used packet sniffers:

- dSniff
- Wireshark
- LanDetective
- Microsoft Network Monitor
- Capsa
- tcpdump
- SkyGrabber
- Xplico

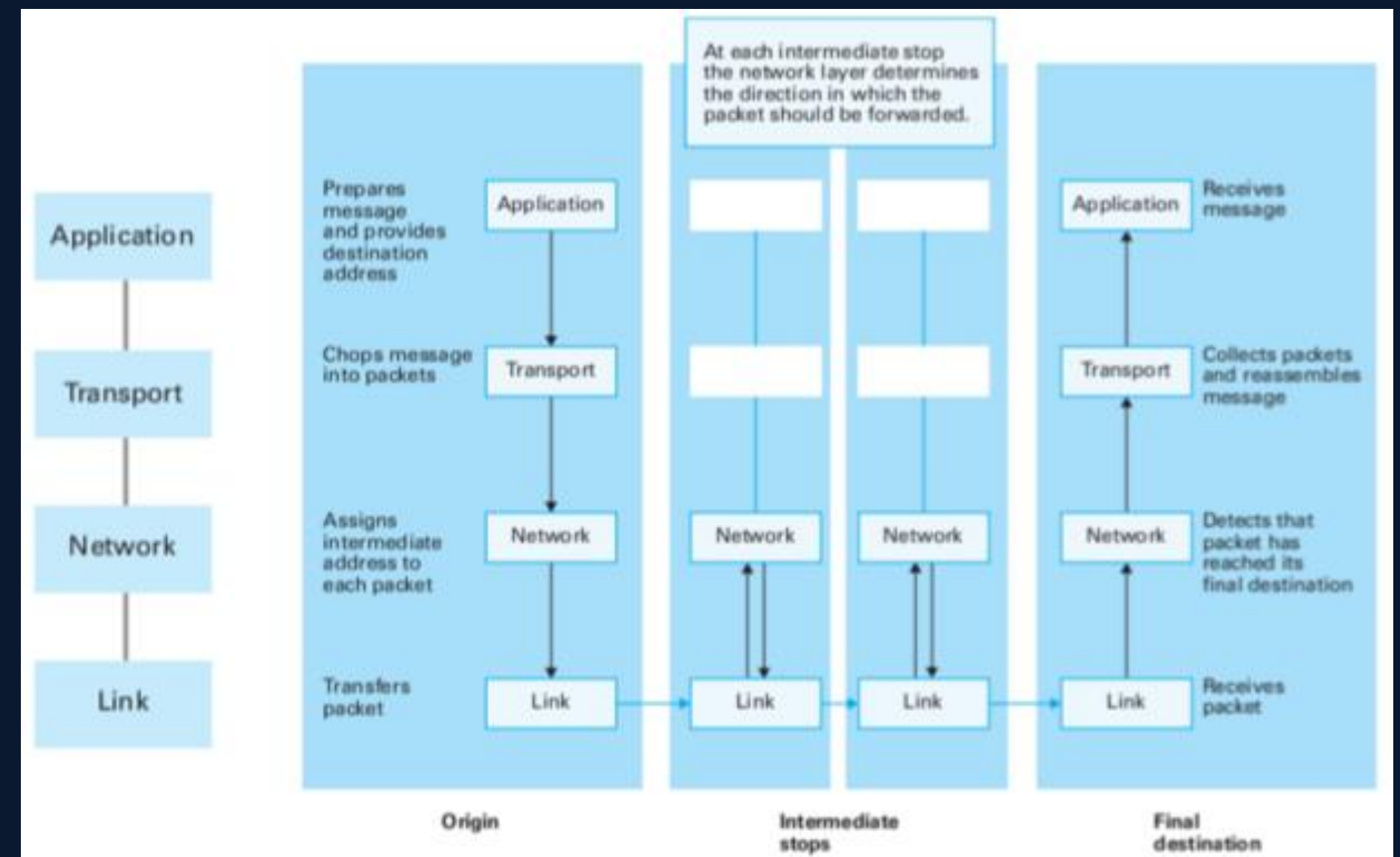
TCP/IP Network Model and Packet Structure



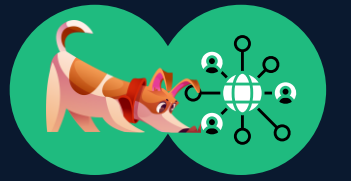
An Example Layered Approach



Network Layer



Address Resolution Protocol (ARP) & MAC Addressing



MAC Addressing

Definition: A MAC (Media Access Control) address is a 48-bit identifier that uniquely identifies a device on a local network segment.

Format: Six pairs of hexadecimal digits separated by colons (e.g., 00:1A:2B:3C:4D:5E). The first three pairs identify the device manufacturer, while the last three pairs identify the specific device.

Address Resolution Protocol (ARP)

Definition: ARP is a protocol that maps IP addresses to MAC addresses on a local network.

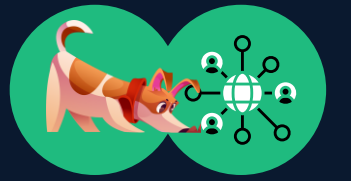
How ARP Works:

- A device wants to communicate with another device on the same network but only knows the other device's IP address (e.g., 192.168.1.100).
- The device sends an ARP Request broadcast: 'Who has IP address 192.168.1.100? Tell me your MAC address.'
- The device with that IP address responds with an ARP Reply: 'I have IP 192.168.1.100 and my MAC address is AA:BB:CC:DD:EE:FF'.
- The requesting device stores this information in its ARP cache (local memory) for future reference.

ARP Vulnerabilities:

ARP is fundamentally insecure because it has no authentication mechanism. Any device can send an ARP reply, whether or not it was asked. This makes ARP vulnerable to spoofing attacks, where an attacker sends forged ARP replies to redirect traffic.

ARP Poisoning/Spoofing Attacks



What is ARP Poisoning?

ARP poisoning (also called ARP spoofing) is an active sniffing technique where an attacker sends forged ARP replies to corrupt the ARP cache of target devices. By doing this, the attacker can redirect traffic destined for one host to the attacker's machine instead.

How ARP Poisoning Works

Step 1: Reconnaissance The attacker identifies the target devices and their IP addresses.

Step 2: ARP Spoofing The attacker sends forged ARP replies claiming that their MAC address is associated with the target's IP address.

Step 3: Cache Poisoning The target device receives these fake ARP replies and updates its ARP cache, now associating the attacker's MAC address with the legitimate IP address.

Step 4: Traffic Redirection. All traffic intended for the legitimate host is now sent to the attacker's machine instead.

Man-in-the-Middle (MITM) Position

Once an attacker successfully performs ARP poisoning, they achieve a Man-in-the-Middle (MITM) position. This means the attacker can now intercept, inspect, modify, or block communications between the victim and the intended recipient. The victim is unaware that their traffic is being intercepted.

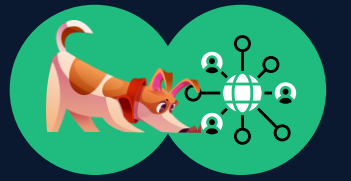
Real-World Attack Example

Victim A (192.168.1.10) wants to access a bank website at the gateway (192.168.1.1). The attacker (192.168.1.100) sends ARP poisoning packets:

- **To Victim A:** 'Gateway 192.168.1.1 is at MAC AA:AA:AA:AA:AA:AA' (attacker's MAC)
- **To Gateway:** 'Victim A 192.168.1.10 is at MAC AA:AA:AA:AA:AA:AA' (attacker's MAC)

Now the attacker intercepts all traffic between Victim A and the gateway, potentially capturing login credentials.

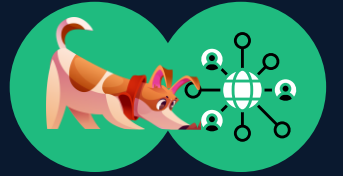
ARP Poisoning/Spoofing Attacks (Cont'd)



Man-in-the-Middle (MITM) Position

- The attacker intercepts communication between two victims.
- Victim A → MiTM → Victim B.
- Victim A ← MiTM ← Victim B.

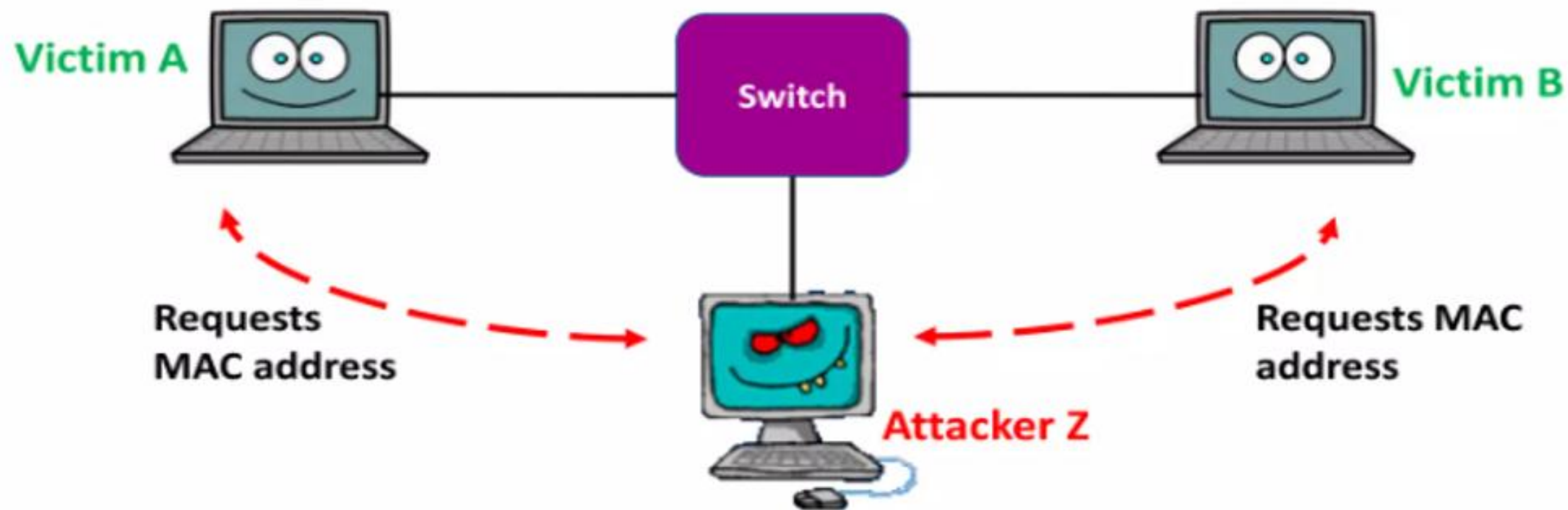
ARP Poisoning/Spoofing Attacks (Cont'd)



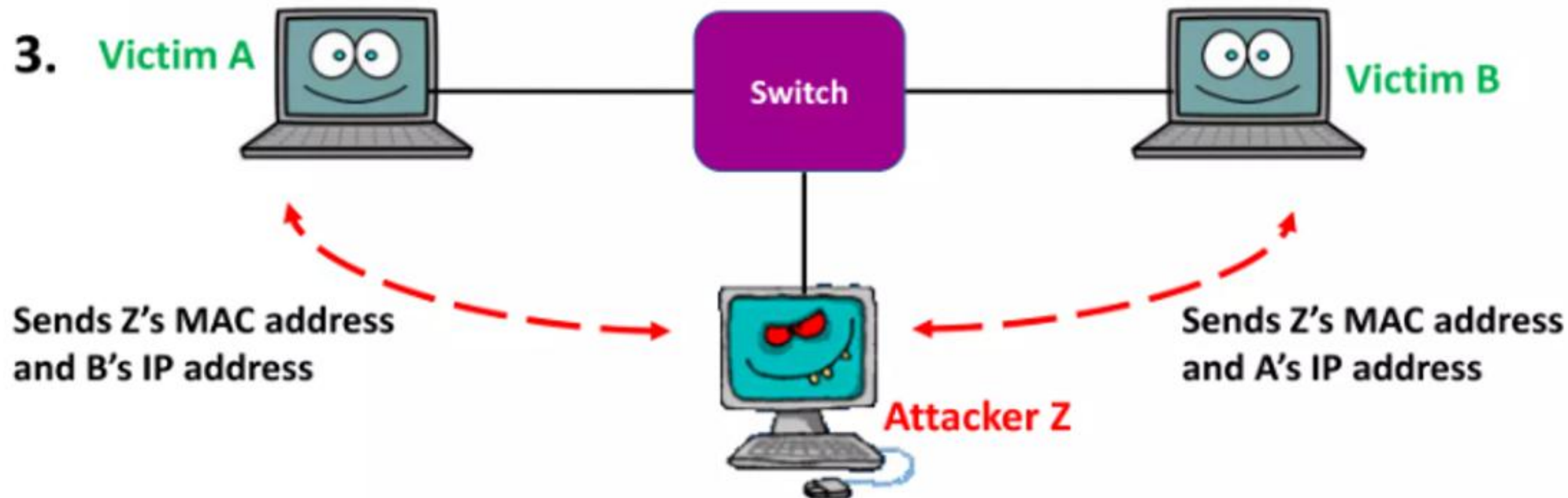
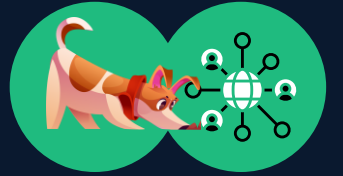
- Nothing prevents other computers from replying to the ARP request.
- Attacker sends “fake” ARP messages.
- Thus mapping attacker’s MAC address with another victim’s IP address.
- All packets sent to the victim will now be directed to the attacker.

➤ Steps:

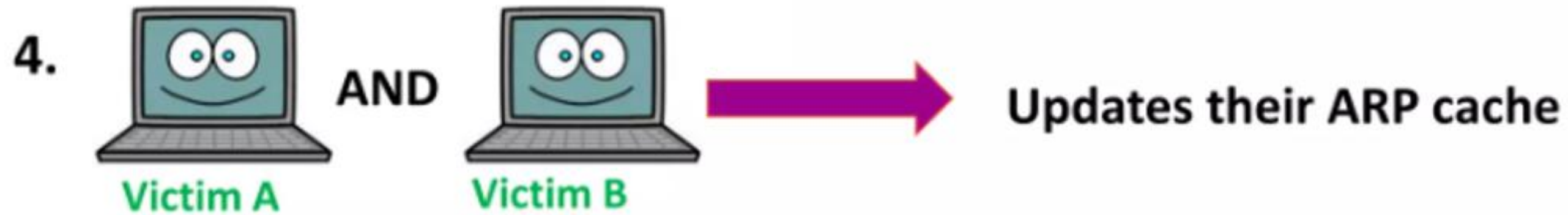
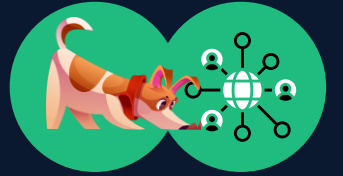
1.



ARP Poisoning/Spoofing Attacks (Cont'd)



ARP Poisoning/Spoofing Attacks (Cont'd)



A's ARP Cache

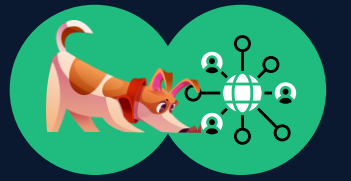
IP Addresses	MAC Addresses
B's IP Address	Z's MAC Address
Z's IP Address	Z's MAC Address

B's ARP Cache

IP Addresses	MAC Addresses
A's IP Address	Z's MAC Address
Z's IP Address	Z's MAC Address



DNS Spoofing



What is DNS Spoofing?

DNS spoofing (also called DNS cache poisoning) is an attack where an attacker provides false DNS responses to redirect users to malicious websites. Instead of resolving a legitimate domain name to the correct IP address, the attacker's DNS response resolves the domain to the attacker's server.

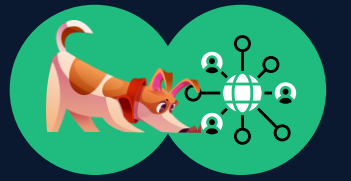
Common DNS Spoofing Methods

- Cache Poisoning (Kaminsky Attack): Exploits DNS resolver vulnerabilities by flooding them with forged DNS responses, causing them to cache the attacker's malicious IP address.
- Local DNS Hijacking: Malware modifies the system's hosts file to redirect domain names locally.
- Rogue DHCP Server: Attacker runs a malicious DHCP server that assigns attacker-controlled DNS servers to victim machines.
- Man-in-the-Middle DNS Interception: Attacker intercepts DNS queries and responds with malicious IP addresses.

What Can Be Sniffed via DNS Spoofing?

- Credentials: Victims redirected to fake login portals can have their usernames and passwords stolen.
- Sensitive Information: Form data, credit card numbers, and personal information entered on spoofed sites.
- Browsing Patterns: Attackers can log which websites users attempt to visit.
- Malware Delivery: Users can be directed to download malicious software.
- Infrastructure Data: Internal DNS records and network topology information.

DHCP Spoofing



DHCP Overview

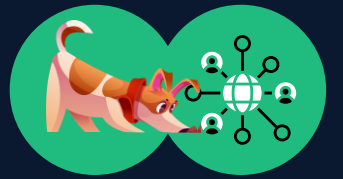
DHCP (Dynamic Host Configuration Protocol) is used to automatically assign IP addresses and network configuration to devices when they connect to a network. The DHCP process involves four steps: Discover, Offer, Request, and Acknowledge (DHCP DORA).

DHCP Spoofing Attack

An attacker runs a rogue DHCP server on the network. When a new device attempts to obtain an IP address, the rogue DHCP server responds faster than the legitimate DHCP server, assigning the attacker-controlled gateway and DNS servers to the victim.

It achieves the same effect as ARP poisoning but through DHCP: redirecting all traffic through the attacker's machine and allowing DNS spoofing.

Mitigation Strategies



Encryption Technologies

- HTTPS/TLS: Encrypts data in transit, preventing the interception and sniffing of credentials and sensitive information.
- VPN: Encrypts all traffic through an encrypted tunnel, hiding data from network sniffers.
- SSH: Provides encrypted remote access, replacing insecure protocols like Telnet.

ARP Protection

- Static ARP Entries: Manually configure critical devices with static ARP mappings.
- Dynamic ARP Inspection (DAI): Cisco switches can validate ARP packets and block spoofed ARP replies.
- MACsec: Encrypts and authenticates data-link-layer traffic.

DNS Security

- DNSSEC: Digitally signs DNS responses to prevent spoofing.
- DNS-over-HTTPS (DoH): Encrypts DNS queries over HTTPS.
- DNS-over-TLS (DoT): Encrypts DNS queries over TLS.

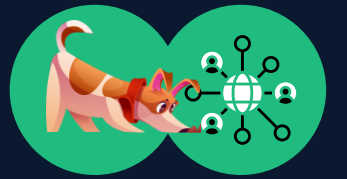
Network Monitoring

- IDS/IPS: Intrusion Detection and Prevention Systems can detect abnormal ARP traffic patterns.
- Network Segmentation: Isolate critical systems and limit access through firewalls and VLANs.
- DHCP Snooping: Switch-based feature that prevents rogue DHCP servers.

User Education

- Security Awareness Training: Educate users about phishing and social engineering.
- Certificate Validation: Teach users to check for valid SSL/TLS certificates and HTTPS.
- Password Hygiene: Encourage strong, unique passwords and multi-factor authentication.

Key Concepts Summary & Takeaways



Remember these key points:

- Network sniffing can be used for legitimate security purposes, but is a powerful tool for attackers.
- Passive sniffing is undetectable but limited to broadcast networks; active sniffing works on switched networks but is detectable.
- ARP poisoning enables MITM attacks by corrupting ARP caches with forged replies.
- DNS spoofing redirects users to malicious sites and can steal credentials and sensitive information.
- Encryption, network monitoring, and user education are essential for defending against sniffing attacks.
- Always obtain authorization before performing any sniffing activities, even for testing purposes.

Thank You

ANY QUESTIONS?

